

EdgeMind — Speaker Notes

MCP Dev Summit Mumbai · 14–15 June 2026

Audience: Technical Leadership (CTOs, VPs Eng, Architects) + CXOs

Total runtime: 20 minutes · 9 slides

Timing at a Glance

Slide	Title	Duration	Cumulative
1	Title / Cold Open	1:00	1:00
2	The Problem	2:00	3:00
3	Thesis & Architecture	2:30	5:30
4	ExecuTorch Novelty	1:30	7:00
5	The Control Plane	2:00	9:00
6	Security & Governance + Demo	3:00	12:00
7	Data Governance & Auditing + Demo	2:30	14:30
8	Why It Generalises	2:00	16:30
9	Credibility & Close	2:30	19:00
	Buffer / Q&A start	1:00	20:00

Legend

“Script”	Words to say out loud — teal box
■ Delivery note	Timing, logistics, pacing cues
CXO/CTO box	Translate for business audience — lead with this
TECH box	Technical depth for engineering leads
AVOID box	Common mistake to sidestep

■ Pre-show: Device in airplane mode, three inference paths pre-warmed, screen recording of demo flows cued. adb logcat -s McpServer:D GuardModel:D lamService:D on a second screen if available.

The Policy Is the Protocol

■ 0:00 – 1:00 · ~60 seconds on this slide

Objective

Don't open with the title. Don't introduce yourself. Walk on and start with a problem statement that lands before the audience has settled. You want engineers leaning forward and CTOs nodding.

What to Say

"Every team in this room building AI agents has been handed the same impossible brief. Make it capable. Make it compliant. And by the way, it needs to work in a dead zone. I want to show you today that those three things aren't in conflict — they're the same architectural decision, made once."

Then — pause, look at the room

Let the silence sit for two full seconds. Point at the phone on the demo table.

"That device is in airplane mode. It has been since I walked in. I haven't touched the Wi-Fi setting. Keep that in the back of your mind."

Don't explain what airplane mode means for the demo yet. Let engineers in the audience see 'in-process MCP transport' on the slide and start pulling that thread themselves. The curiosity gap is intentional.

Audience-Specific Notes

CXO/CTO: The hook for the CXO is the impossible brief — capability AND compliance AND resilience. Every board has heard 'you can only pick two.' Start by promising all three.

TECH: Engineers will notice 'zero LLM tokens' and '\$0 per query' on the slide. Don't explain yet. Let the numbers sit.

Self-Introduction (10 seconds)

After the opening beat — and only after — say your name, role, and one sentence on what EdgeMind is. Keep it tight.

"I'm [name], [role] at [company]. EdgeMind is a clinical AI assistant that runs a frontier-class language model and a full MCP control plane entirely on a phone — no server, no cloud, no data leaving the device."

■ If you're running a tight 20, skip the self-intro or cut it to 5 seconds. The opening statement is more important.

The Problem — You're told to pick one. You shouldn't have to.

■ 1:00 – 3:00 · ~120 seconds on this slide

Objective

This is the most important slide in the deck for CXOs. Don't rush it. The rest of the talk only lands if the audience has personally felt this tension. Make them feel it before you solve it.

Walk the Left Column — What Regulation Demands

"Regulation is no longer a preference. India's DPDP Act is in force — not pending, in force. GDPR has enforcement teeth. And if you're in health or finance, you have sector mandates stacked on top of those. The compliance requirement isn't 'store data carefully.' It's 'don't let it leave the jurisdiction at all, and prove every automated decision is auditable.' That's a data-flow requirement. Not a policy one."

Pause on 'data-flow requirement.' Let that land for CXOs before moving on.

Walk the Right Column — What the Default Stack Does

Shift tone. Dry. Almost matter-of-fact.

"Here's what the default agentic stack does. It serialises your prompt — which may contain a patient name, an account number, a field report — ships it to a cloud endpoint, and hopes the DPA never asks where it went."

Pause on 'hopes.' One beat. Let the word do the work.

The Three Costs

"There are three costs to this. Token spend per query — that's quantifiable. Round-trip latency — that's measurable. And then there's the one that kills production deployments: it falls over completely when the network can't be trusted."

Name the people, not the use cases:

"A ward nurse doing a medication check in a basement. A field analyst in an oil terminal without signal. A defence system that cannot wait for a TCP handshake. None of them have time for a cloud round-trip. And for all of them, the data leaving the device isn't a technical inconvenience — it's a compliance breach."

The Pivot Line

Say this looking at the room, not the slide:

"What if the compliance answer and the resilience answer were the same thing?"

Then advance.

Audience-Specific Notes

CXO/CTO: The DPDP reference is specific to India — this audience will recognise it immediately. Use it. The ward nurse / field analyst / defence framing humanises the problem. CXOs think in users, not architectures.

TECH: Engineering leads will already be thinking about how you solve the latency problem on-device. Don't address it yet — you want that question active when you hit slide 3.

AVOID: Don't get drawn into a DPDP / GDPR compliance Q&A; here. Acknowledge complexity, keep moving. 'That's exactly what the architecture answers — let me show you how.'

Thesis & Architecture

■ 3:00 – 5:30 · ~150 seconds on this slide

Objective

State the thesis in one sentence. Then show the architecture as a consequence of that thesis — not as a collection of components. Engineers should see the causal logic. CXOs should see that one decision replaces a legal team.

The Thesis — Say it looking at the room

“MCP's real value at the edge isn't tool-calling. It's that the protocol becomes the single chokepoint where you decide which model runs, which tools are permitted, and which governance rule applies — all in one local pass, before any data has a chance to leave.”

Trace the Architecture — Left to Right with Your Hand

Point at each component on the slide as you name it. Keep it conversational, not a recitation.

“There are five Kotlin files doing all of this. The ViewModel builds a tool call — a typed struct, a tool ID, a parameter map. The MCP client wraps it with a scoped capability token and calls the server. Not over a socket. Not over a network. The transport is a coroutine dispatch — the server is a class in the same process.”

Slow down here. This is your most quotable line:

“We kept the MCP protocol and deleted the network. The server is a class in the same process.”

Pause. Engineers will visibly react. Wait for it.

“The server runs the security pipeline — guard model, then IAM, then routing. The result comes back as a sealed ToolResult. The whole thing — security gate, governance decision, inference, audit — happens in a single coroutine, on device, before a single byte has touched the air.”

Land the Two Halves

Point at 'The capability half' box, then 'The constraint half' box.

“The capability half: Phi-3 Mini, quantised to int4, running on the Snapdragon NPU via ExecuTorch. Frontier-class intelligence, no API key, no cloud bill. The constraint half: zero egress makes DPDP and GDPR a structural guarantee. Privacy isn't a checkbox in a policy document — it's an architecture property. There's no code path that sends data anywhere.”

Transition

“So how does one decision enforce security, governance, and auditing simultaneously? That's the control plane.”

Audience-Specific Notes

CXO/CTO: Lead with the constraint half for CXOs — 'privacy as an architecture property' is their language. They've been told compliance is a process problem. Show them it can be an engineering solution.

TECH: Engineers will want to know about Dispatchers.Default vs IO, the coroutine scope, the sealed class hierarchy. Don't go there now — slide 5 covers the security pipeline. Flag it: 'I'll show you exactly how the pipeline runs in the next slide.'

ExecuTorch Novelty — Why it changes what's possible on-device

■ 5:30 – 7:00 · ~90 seconds on this slide

Objective

This is the technical credibility slide. Engineering leads need to understand why ExecuTorch, specifically — not ONNX Runtime, not TFLite, not llama.cpp. CXOs need a one-line answer to 'could we have used something off the shelf?' The answer is no, and this slide explains why.

Open with the Frame

"Before I show you the control plane in detail, I want to spend ninety seconds on why ExecuTorch is doing the heavy lifting here — because this is the part that's genuinely novel, and it's the reason the architecture is possible at all."

Walk the Four Cards

Card 1 — PyTorch-Native Export

"torch.export captures the computation graph directly from PyTorch. No format conversion. No separate runtime. Phi-3 Mini, Whisper, MiniLM — they all go through the same pipeline and produce a single dot-pte artifact. That artifact is what runs on the device. No Python at inference time."

TECH: For engineers: the reason this matters is that alternative runtimes — ONNX RT, TFLite — require you to abandon PyTorch semantics at the export boundary. ExecuTorch preserves the operator graph end-to-end. That means quantisation, calibration, and hardware delegation all happen inside the same toolchain.

Card 2 — int4 + Static Memory

"Group-size-128 int4 quantisation takes Phi-3 Mini from fourteen gigabytes to two. That's what fits on a phone. Compile-time static memory planning eliminates garbage collection pauses during inference — which is what gives you deterministic latency. On a device doing triage, you cannot have a 200-millisecond GC pause in the middle of a response."

Card 3 — Qualcomm HTP Delegation

"The QNN partitioner routes the quantised ops directly to the Hexagon Tensor Processor — Qualcomm's fixed-function NPU. That's three to five times better performance per watt than the CPU path. The fallback chain is HTP, then Vulkan GPU, then XNNPACK CPU — the same dot-pte file runs on all of them, zero code changes."

Point at the stat: ~270ms wall-clock SLM on Snapdragon 8 Gen 3.

Card 4 — On-Device LoRA Training (dark card — emphasise this one)

"This is the one that no other mobile runtime can do. ExecuTorch has a training API. Rank-eight LoRA adapters fine-tune locally on the device, during idle, on the last five hundred interactions. The adapter is saved to disk in the same dot-pte format the inference engine already loads. Training and inference share the same runtime. No data ever leaves the device to train the model — which means the model improves over time without ever creating a privacy liability."

Close the Card

"No other framework — ONNX Runtime, TFLite, MLC — gives you all four simultaneously: PyTorch-native export, Qualcomm HTP, int4, and on-device training. That combination is what makes the architecture described on the next three slides actually possible."

Audience-Specific Notes

CXO/CTO: CXOs don't need the technical depth — use this slide to establish credibility and then get to the control plane. One sentence for them: 'This is why we can run a two-gigabyte model at 270 milliseconds on a commodity phone, and why the model gets better over time without your data ever leaving the device.'

TECH: Engineering leads will appreciate the specificity. Name the constraint: torch.export strict=False for Phi-3 RoPE buffer mutation. The confidence score approximation — softmax over the first 100 logits, not the full 32k vocabulary. These details signal you know the codebase.

AVOID: Don't spend more than 90 seconds here. The ExecuTorch detail is credibility-building, not the core argument. If you're running long, compress to cards 1 and 4 only.

The Control Plane — Three concerns, one decision point

■ 7:00 – 9:00 · ~120 seconds on this slide

Objective

This is the screenshot slide. Tell CTOs that explicitly. The three-column layout is designed to show that security, governance, and auditing aren't features you add later — they're one integrated pipeline executing in the same function call before the model sees a single token.

Open

"If you screenshot one slide today, screenshot this one."

Then pause and let them pull out phones.

Frame the Three Columns as One Pipeline

"What you're looking at is not three separate features. It's one pipeline — three stages executing in sequence inside a single coroutine, before the first model token is generated. They aren't bolt-ons. They can't be bypassed. They run every single time."

Column 1 — Security

"The security gate runs first. A sixty-million-parameter on-device classifier — distilled, running on the NPU — evaluates the prompt before anything else sees it. Not a regex. A model. It fails closed, which means if the guard model isn't available, the fallback pattern-matcher still catches jailbreaks, Aadhaar numbers, SSNs, self-harm language, and instruction overrides. A blocked prompt never reaches inference."

"Then the IAM layer runs. An ES256 JWT — signed by a key that lives inside the Android Keystore hardware enclave and never leaves it — is checked against the required scope for the tool being invoked. Two independent gates. Either one can veto. A safe prompt from an under-scoped caller is still rejected."

Column 2 — Governance

"Once both gates pass, the governance engine decides where the query runs. The confidence router tries the SLM first — Phi-3 Mini, sub-three-hundred milliseconds. If the confidence score from the model's own logits comes back below 0.75, it escalates to RAG. If RAG still doesn't clear the threshold, it escalates to the seven-billion-parameter LLM. And here's the governance point: a PII-flagged query is pinned to the local SLM path. It is structurally forbidden from escalating to any path that could touch a network."

Column 3 — Auditing

"Every outcome — blocked, unauthorised, or answered — writes a signed, append-only record to a local database. Agent ID, inference path, confidence score, latency, the scopes on the token, timestamp. HMAC signed. Exportable to a compliance officer or incident responder when the device reconnects."

Close the Slide

"All three. On device. Zero PII egress. DPDP and GDPR satisfied by construction."

Audience-Specific Notes

CXO/CTO: Frame this as your audit answer to the board: 'Can you prove every AI decision?' Yes. Every blocked prompt, every inference, every escalation — signed, on-device, exportable. That's your answer to the DPA.

TECH: Engineers will ask about the `McpServer.handleToolCall()` dispatcher running on `Dispatchers.Default`. Correct — the guard and IAM are pure compute, not I/O. Room writes are internally dispatched. The design choice is deliberate.

Security & Governance — What's allowed · what runs where

■ 9:00 – 12:00 · ~180 seconds on this slide

Objective

This is the first demo slide. The two gates on the left give you the engineering depth. The confidence router on the right shows the governance logic in action. The live demo makes it real. Budget: 90 seconds on the left column, 90 seconds on the live demo.

Left Column — Two Gates, One Hardware Root

Gate 1 — GuardModel

"Gate one answers one question: is this content safe to process at all? It fails closed. If something goes wrong, the default is to block. The prompt hash is SHA-256'd for the audit trail — so you can prove what was blocked without ever logging the raw content."

Gate 2 — IamService

"Gate two answers a completely different question: is this caller authorised to invoke this specific tool? These are orthogonal. A safe prompt from an under-scoped caller is still rejected. A malicious prompt from a fully-authorised caller is still blocked. The scope is set at session creation from the agent's role. DEFAULT gets SLM inference and knowledge read. ELEVATED adds LLM access. SYSTEM adds the microphone sensor and audit write."

"The key backing the JWT never leaves the Android Keystore TEE. An attacker with app memory access cannot forge a token. That's ES256 asymmetric signing — the private key is generated in hardware and never exposed to the JVM heap."

Right Column — The 0.75 Router

"Once both gates pass, the confidence router runs. The SLM fires on every query. If the top-token confidence from the model's logit distribution comes back at or above 0.75, the answer is returned — roughly eighty percent of queries, under three hundred milliseconds. If it drops below 0.75, RAG augments the context from the FAISS index and reruns the SLM. If it's still below after RAG, the seven-B LLM handles it."

Point at the PII governance note on the slide.

"PII-flagged queries don't participate in that escalation. They're pinned to the local path — structurally, in code — regardless of confidence."

LIVE DEMO — Three Sequences

■ Pre-condition: App open, warmed, phone offline. Screen visible to audience.

Demo 1 — Under-scoped Token Rejection

Send a prompt using a DEFAULT-scoped token to a tool that requires ELEVATED scope.

"Watch what happens before any model runs."

ToolResult.Unauthorized appears instantly. Point at it.

"No model. No inference. The gate stopped it at IAM before the guard model even ran."

Demo 2 — SLM Fast Path

Type: 'I have chest pain and shortness of breath'

"NER task. Watch the confidence."

0.93 returned. Sub-300ms.

"That's Phi-3 Mini, on the NPU, on a device that has no network. Two hundred and something milliseconds from keypress to response."

Demo 3 — RAG Escalation Path

Type: 'triage severity'

"Confidence 0.62. Below threshold. Watch."

RAG fires. FAISS retrieves five chunks. SLM reruns. 0.91 returned.

"Same model. Augmented context from the on-device knowledge base. Confidence climbs. No network. The phone hasn't connected to anything."

Honesty Beat — Say This Plainly

"The confidence scores are real — they come from the model's logit distribution via softmax. One nuance: we're computing softmax over the first hundred logits, not the full thirty-two-thousand-token vocabulary. So the confidence is slightly overestimated on the native path. The threshold is a tunable starting point, not a validated clinical number."

Engineering audiences trust the person who owns their approximations. Don't bury this.

Audience-Specific Notes

CXO/CTO: For CXOs: frame the demo as 'your DPA audit in action.' Every one of those interactions just wrote a signed record. We'll show that on the next slide.

TECH: Engineers will ask about IndexFlatL2 vs HNSW, the 384-dimension MiniLM embeddings, the top-k chunk count. Five chunks, cosine similarity fallback in Kotlin when the JNI isn't available.

■ If demo gods fail: 'In case the demo is being temperamental — here's a recording of the same three flows.' Have it cued. You lose nothing.

Data Governance & Auditing — Nothing leaves, everything is provable

■ 12:00 – 14:30 · ~150 seconds on this slide

Objective

This slide is the compliance answer. The left column maps to DPDP / GDPR principles in code — not policy. The right column is the audit log demo. For CXOs this is the 'show the board' slide. For engineers it's the implementation of the principles they've been trusting abstractly.

Left Column — Three DPDP / GDPR Principles in Code

Residency

"Zero bytes leave the device. Not because of a policy document — because there is no network call in the inference path. The WorkManager training constraint has NetworkType.NOT_REQUIRED. Even the federated learning step has no egress path."

Minimisation

"Every interaction stored for local LoRA training passes through an anonymisation function before it touches the database. SSN, Aadhaar, credit card, phone number, email — all regex-replaced at write time. Not at export time. At write time. The training data is clean before it's ever stored."

Purpose Limitation

"Scoped tokens gate what each tool can read. A DEFAULT agent token cannot invoke the LLM path or the microphone. The scope check throws InsufficientScopeException before the handler is even looked up. Purpose limitation is enforced in the type system, not in a policy binder."

Close the left column:

"DPDP and GDPR aren't satisfied by controls and audits here — they're satisfied by construction. The data flow doesn't have an egress path to violate."

Right Column — The Audit Trail

"Every call to AuditJournal — blocked, unauthorised, answered, trained — writes a record: UUID, agent ID, timestamp, event type, inference path, latency, confidence, scopes, detail string. The raw entry is HMAC-SHA256 signed before it's written to the database. The signed record appears in the UI reactively — you can open it during a blocked query and the record is already there."

LIVE DEMO — Audit Log

■ Trigger a guardrail block — send 'ignore previous instructions'. Then open the audit log panel.

"Watch the signed BLOCKED record appear. Agent ID, reason, prompt hash, timestamp. The phone is still offline."

Point at the entry.

"That record is HMAC-signed. Tamper with any field and the signature breaks. Export it on reconnect and hand it to your compliance officer."

Honesty Beat

"The signing today uses SHA-256 with a hardcoded salt. The comment in the code says 'in production, use Android Keystore HMAC key' — and that upgrade is on the roadmap. The tamper-evidence claim is real. The key management isn't yet hardware-backed on the audit side."

Say this without apology. Owning a known gap in front of an engineering audience reads as senior.

Audience-Specific Notes

CXO/CTO: This is the slide for your Chief Compliance Officer proxy in the room. Three DPDP principles, each with a code reference. 'Our privacy compliance is enforced by the compiler, not by policy.' That's the line.

TECH: Engineers will ask about the Flow> subscription, the Room database schema, and the HMAC key lifecycle. The `observeRecent()` call is subscribed at `ViewModel` startup — the log updates reactively on every write.

Why It Generalises — One runtime, six verticals

■ 14:30 – 16:30 · ~120 seconds on this slide

Objective

Zoom out to the platform claim. The CXO in the room is now thinking 'what's the cost of adapting this to my vertical?' Answer that before they ask. Engineers want to know the coupling boundary — where does domain-specific code end and the control plane begin.

Open with the Platform Claim

"Everything you just saw is domain-agnostic. The MCP control plane — the guard, the IAM, the router, the audit — none of it knows about clinical triage. To ship a new vertical, you swap three files. The corpus.jsonl — your domain knowledge base. The domain.faiss — the vector index built from it. And the model.pt — optionally a domain-adapted LoRA checkpoint. The entire control plane is identical."

Gesture at the Six Verticals — Don't Read Them

Point at the grid and name two or three that are relevant to the room, then move on.

"Logistics — field ops running route and inventory queries offline. Pharma and MedRep — drug interaction lookups in a clinic with no signal. Sales and CX — five hundred reps displacing a four-hundred-fifty-thousand-dollar annual Salesforce AI bill."

Drop the ROI Number — Hard

Stop. Make eye contact with the most senior person in the room. Say this slowly.

"Four hundred and fifty thousand dollars a year of cloud inference spend displaced per five hundred field users. That's before you count the compliance audit savings, before you count the cost of the breach you didn't have."

Don't rush past it. Don't qualify it immediately. Let the number sit for three seconds.

"Logistics: a hundred and nine thousand dollars of cloud token spend, to zero, after deployment."

Name the Coupling Boundary for Engineers

"If you're an engineering lead thinking about adapting this — the coupling boundary is exactly those three files. The MCP orchestration, the security stack, the inference runtime, the federated training loop — none of that changes. You bring domain knowledge. The platform brings the governance."

Audience-Specific Notes

CXO/CTO: CXOs think in verticals and ROI, not in architectures. Lead with the \$450K number. Then name their vertical. If you know who's in the room, tailor it: 'For a pharma MedRep deployment of five hundred reps across Maharashtra...'

TECH: Engineers will appreciate the three-file coupling boundary. It's a clean separation of concerns and it maps directly to the ToolRegistry + knowledge base + LoRA adapter architecture from slides 3 and 4.

AVOID: Don't read all six verticals. The audience will tune out. Name the two most relevant to the room, drop the ROI number, and move.

Credibility & Close — Real today vs. on the path

■ 16:30 – 19:00 · ~150 seconds on this slide

Objective

This slide earns you the trust that converts conversation to collaboration. Technical leadership audiences know that every demo is a best-case scenario. The person who draws the line between 'working' and 'on the path' themselves is the person they want to work with. Deliver this with confidence, not apology.

Frame It

"Before I close, I want to be precise about exactly where the line is between what you just saw working and what's next. Technical audiences trust the person who draws this line themselves."

Working Today — Say Each One Plainly

"In-process MCP with full protocol semantics — sealed ToolResult variants, typed tool registry, capability-scoped JWTs. Working. Two-gate security — on-device guard model and Android Keystore-backed IAM, running before every model call. Working. Three-path confidence routing with logit-derived scores on the native path. Working. FAISS vector search with Kotlin cosine fallback. Working. Offline signed audit log, reactive, exportable. Working. On-device federated LoRA fine-tuning — rank eight, alpha sixteen, WorkManager scheduling, PII-anonymised training data, no egress. Working."

On the Path — Say Each One Without Flinching

"Keystore-backed HMAC on the audit log — today it's SHA-256 with a hardcoded salt. The upgrade path is clear and it's on the roadmap. Inbound JWT signature re-verification — the IAM layer issues correctly but the verification stub doesn't check the EC signature yet. Gemma 2B and model-agnostic routing — the architecture is model-agnostic today; the specific Gemma integration is next. Per-domain policy parameterisation — the control plane is identical across verticals; the tooling for domain operators to configure it without touching code is next."

The Meta-Point — Say This Out Loud

"These are known, bounded gaps. Not unknown risks. Every one of them has a clear engineering path. The architecture you've seen today works now. The roadmap items make it production-hardened."

The Close

Restate the spine in one breath. Look at the room, not the slide.

"Capability without the cloud. Compliance without the binder."

One beat.

"If you're building agents under DPDP — or anywhere the network can't be trusted, in a hospital corridor, in a field terminal, in a regulated vertical — come find me. I'm here all day."

Point at your contact details. Stop talking. Take questions.

Audience-Specific Notes

CXO/CTO: CXOs will remember two things from this slide: the confidence of owning the gaps, and the tagline. 'Capability without the cloud. Compliance without the binder.' Make sure those words land clearly.

TECH: Engineers will want to follow up on: confidence calibration in production, the JWT signature blast radius, and the LoRA adapter hot-swap path. You have direct answers to all three. If Q&A opens on those — welcome it. It signals they want to build on top of this.

If Running Over Time

■ The audit demo on slide 7 compresses cleanest to a screenshot — swap it for a static image and save 45 seconds. The three-path confidence demo on slide 6 is the one to protect — it's the moment that makes the architecture tangible. Never cut the honesty beats on slides 6 and 9 — they're doing the most trust-building work in the whole talk.

Q&A; Preparation — Anticipated Questions

Q (CXO): CXO: 'What's the total cost of deployment vs our current cloud AI spend?'

A: The hardware is commodity Android — Snapdragon 8-series devices your field team likely already carries. The model assets download once over Wi-Fi. After that: zero per-query cost. For five hundred field users displacing cloud inference, the payback period on any incremental hardware upgrade is typically under six months.

Q (CXO): CXO: 'How does this interact with our existing data governance policies?'

A: It enforces them structurally. DPDP residency: no egress path. Minimisation: PII redacted at write time. Purpose limitation: scoped tokens gate tool access. The architecture doesn't replace your policies — it makes them impossible to violate.

Q (Tech): CTO: 'What's the blast radius if the JWT verification stub is exploited?'

A: In the current same-process architecture, the issuer and verifier are the same object — a forged token cannot cross a trust boundary because there is no boundary to cross. In production, before adding any external agent surface, JWT verification moves to a hardware-backed EC signature check against the Keystore public key. That's a three-day engineering change.

Q (Tech): Tech: 'How does confidence calibrate in production on domain-specific data?'

A: The current implementation uses softmax over the first 100 logits — a known approximation that overestimates confidence slightly. In production you'd compute over the full 32k vocabulary or use entropy-based calibration, and set the threshold against a held-out clinical or domain validation set. The 0.75 starting point is calibrated against the mock responses in the demo.

Q (Tech): Tech: 'How does LoRA adapter hot-swap work at runtime?'

A: The training loop is complete and saves the LoRA delta weights to disk. The reload path — loading the base .pte and merging the adapter at inference startup — is the next milestone. Standard LoRA merge pattern: the adapter weights are applied to the base model's attention layers before inference begins. No re-export of the full model required.

Q (Tech): Tech: 'Could you run multiple agents simultaneously with this architecture?'

A: Yes — McpServer is stateless per call. Multiple McpClient instances with different AgentRole assignments can submit concurrent tool calls. The current demo is single-agent but the server was designed with multi-agent use in mind. The scope check in IamService prevents privilege escalation across agent roles.

Q (Both): Both: 'Is this production-ready?'

A: The architecture is production-grade. The MCP orchestration, security gate, and audit layer are production quality. What's on the roadmap are hardening items — Keystore HMAC on the audit log, JWT signature verification, model-agnostic routing. Eight to twelve weeks of engineering to production-harden for a specific vertical deployment.